

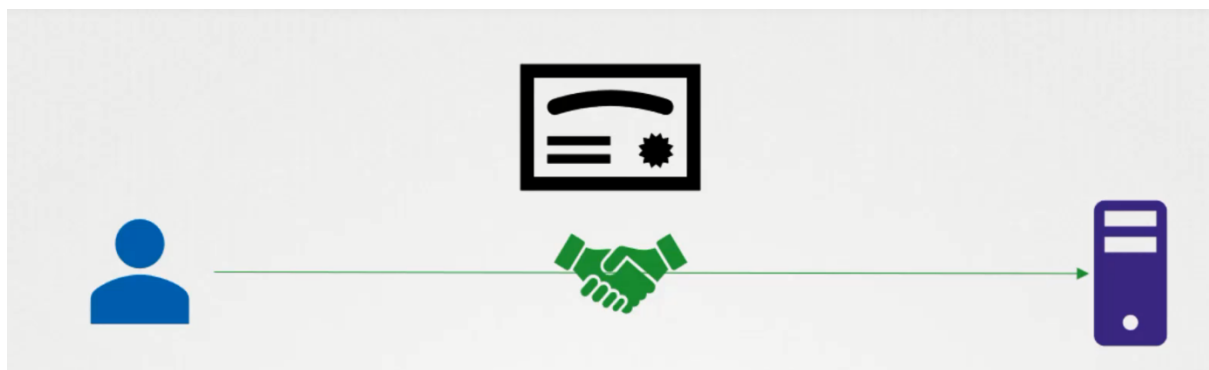
What is SSL?

SSL is an abbreviation for (Secure Sockets Layer). SSL technology is developed by Netscape.

SSL has been created for exchanging private documents on the internet. All popular web browsers support SSL Technology, for the protection of personal information (such as credit card information, passwords). SSL is now very popular. Through SSL, an encrypted connection is established primarily between the web server (host) and the web browser (user). If you are connected to a web server, no third person will be able to understand your activities.

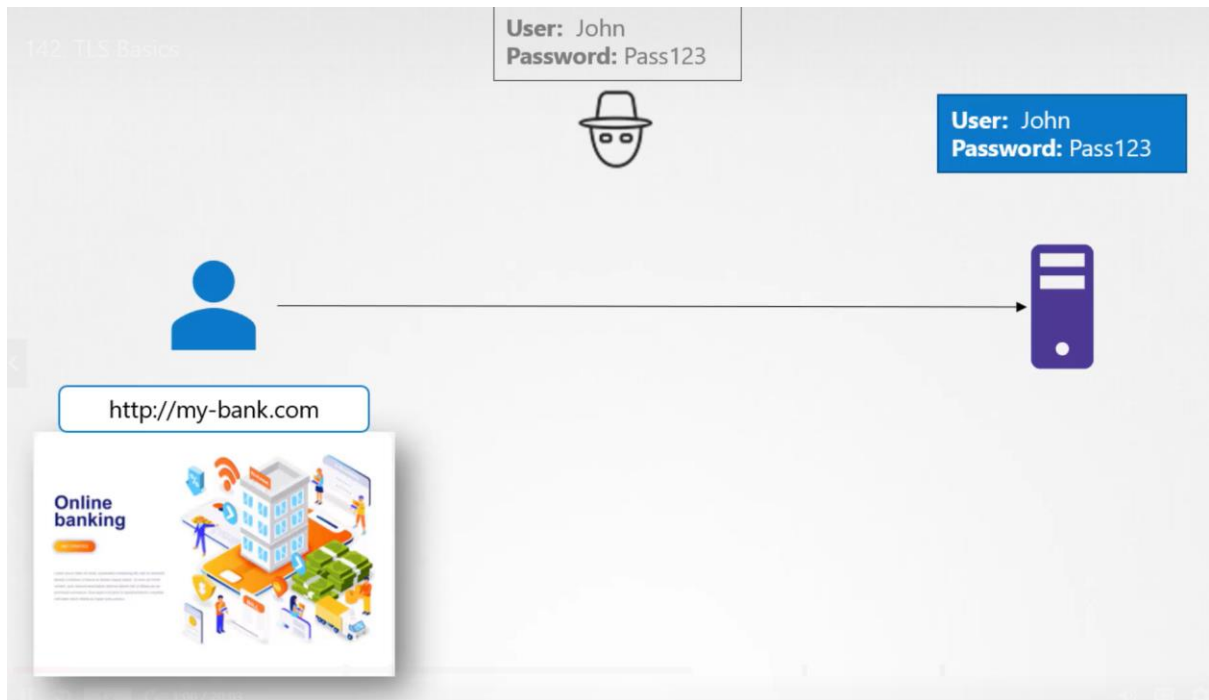
How to secure your web server?

Certificate: is used to guarantee trust between two parties during transaction. TLS certificates are not generally used for web access. Let's say if user wants to access webserver TLS certificate ensures that communication between the user and server is encrypted and server is who it say it is.

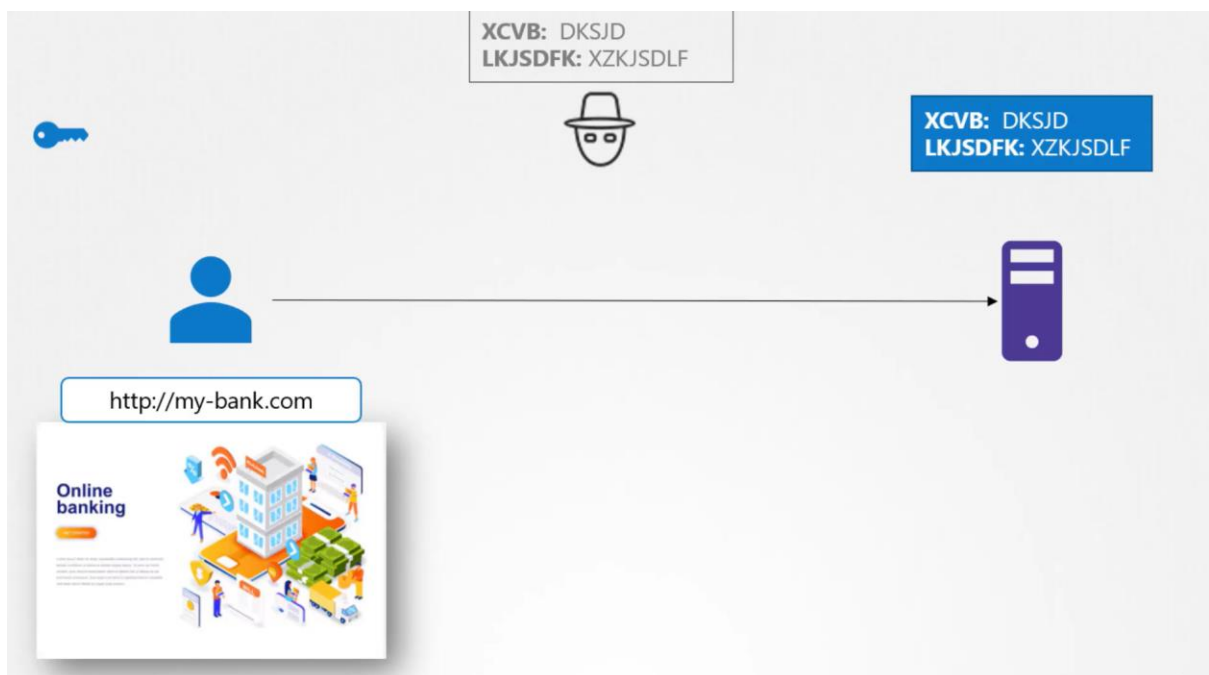


UC: We want to access bank server from the browser.

UC: Without security

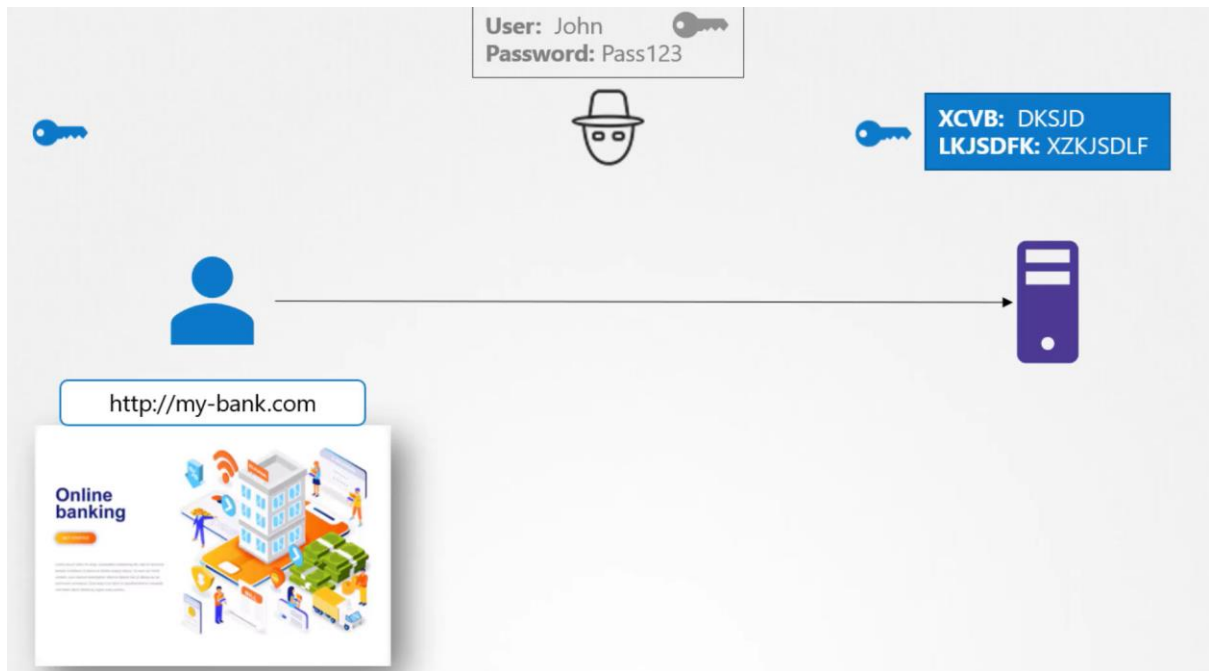


Solution: Encrypt the data using symmetric key and pass the encrypted text to server.



Now hacker have encrypted data, same issue with the server, he also have encrypted data?

Solution: Use send a copy of the key over the network



Hacker can hack the key also because, key also travel through the same network.



Solution: Asymmetric Key

To mitigate this risk **Asymmetric Encryption** comes in picture, rather than using a single key for encryption and decryption data, asymmetric encryption uses a pair of keys public key and private key, for understanding purpose we think as a private key and a public lock. Key is with user hence it is private and a lock anyone can access hence it is public. The trick here is if you encrypt or lock the data with your lock, you can only decrypted it using associated key. So key is always secure with you and not be shared with any other else it's private, but lock is public may be shared with others.

ASYMMETRIC ENCRYPTION

Private Key



Public Lock

User: John
Password: Pass123

UC: You have a server, you don't want to use the password as it is too risky, so you decide to use key-pairs.

step1: generate a key pair using the ssh-keygen command

ASYMMETRIC ENCRYPTION - SSH

```
ssh-keygen  
id_rsa id_rsa.pub
```



Private Key

Public Key

step2: Then you secure your server by locking down all to access it except through the door locked using the public lock

ASYMMETRIC ENCRYPTION - SSH

```
ssh-keygen  
id_rsa id_rsa.pub
```



Private Key Public Lock



ASYMMETRIC ENCRYPTION - SSH

```
ssh-keygen  
id_rsa id_rsa.pub
```



Private Key Public Lock

```
cat ~/.ssh/authorized_keys  
ssh-rsa AAAAB3NzaC1yc...KhtUBfoTz1BqR  
V1NThv0o4opzEwRQo1mWx user1
```



As you see lock is public anyone can try to access it, but can be access only through the private key which is save with you in your laptop.

Step3: When you try to ssh you have to specify the location of your private key in your ssh command.

ASYMMETRIC ENCRYPTION - SSH

```
ssh-keygen  
id_rsa id_rsa.pub
```



Private Key Public Lock

```
cat ~/.ssh/authorized_keys  
ssh-rsa AAAAB3NzaC1yc...KhtUBfoTz1BqR  
V1NThvOo4opzEwRQo1mWx user1
```



```
ssh -i id_rsa user1@server1  
Successfully Logged In!
```

UC: If there are other user wants to access, repeat the same process

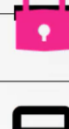
ASYMMETRIC ENCRYPTION - SSH



Private Key



Private Key Public Lock

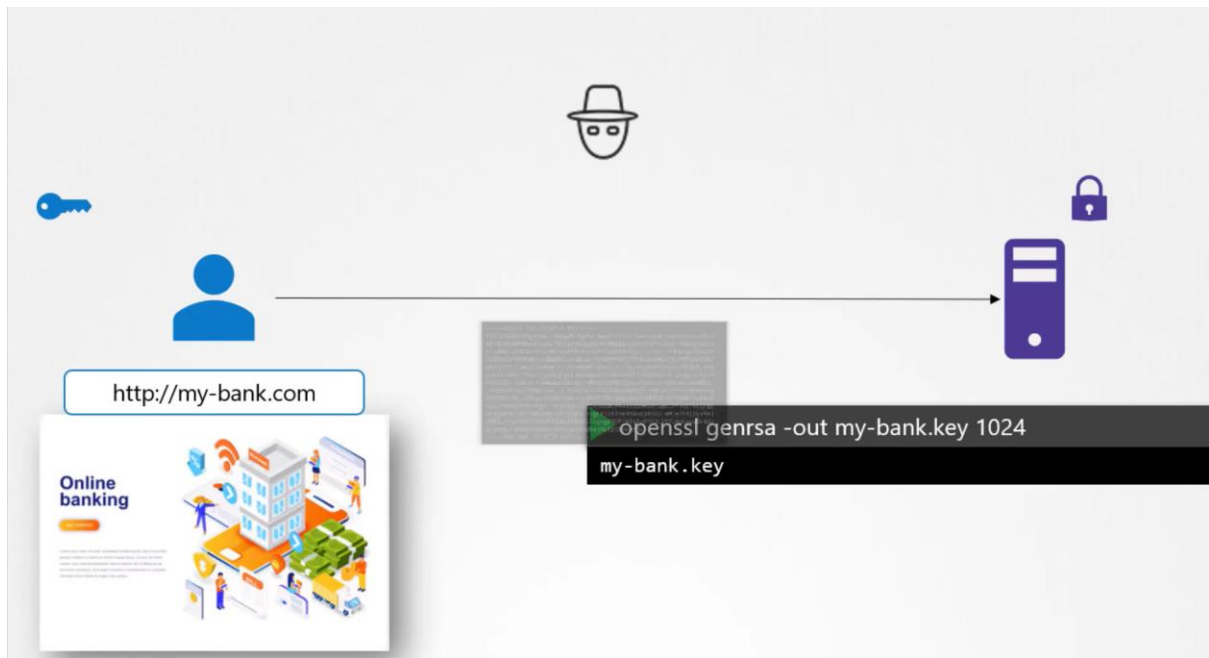


```
cat ~/.ssh/authorized_keys  
ssh-rsa AAAAB3NzaC1yc...KhtUBfoTz1BqRV1NThvOo4opzEwRQo1mWx user1  
ssh-rsa AAAXCVJSDfdf...SLKJSDLKfw23423xckjSDFDFLKJLSDFKJLx user2
```

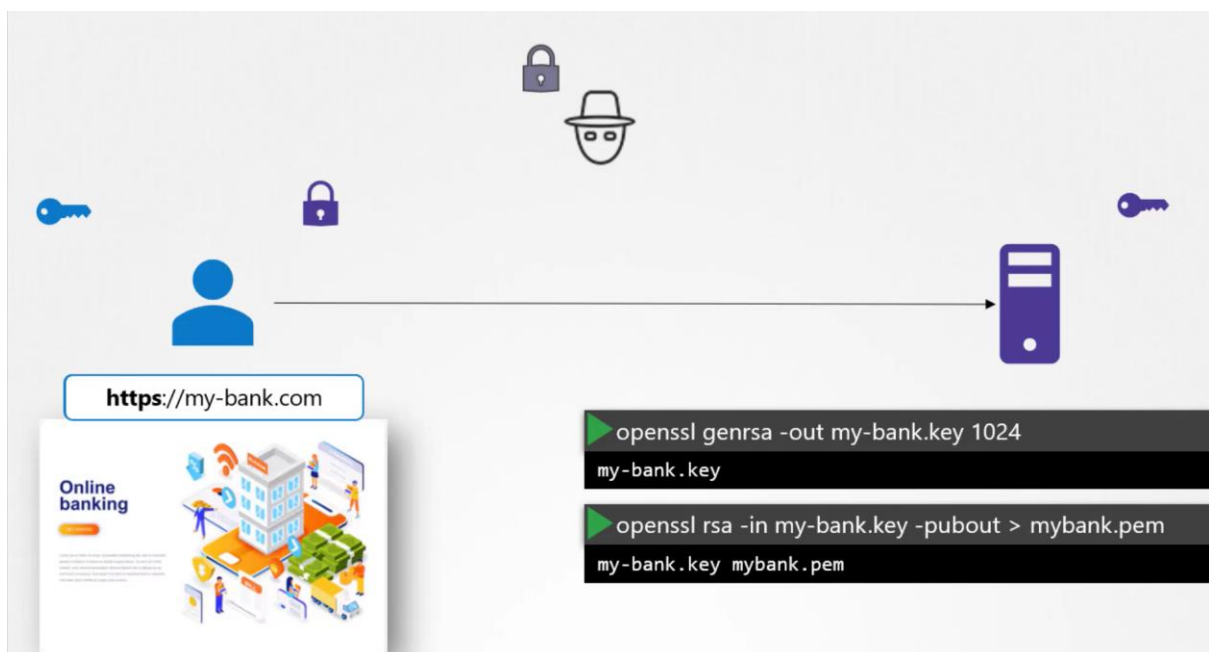
UC-our web example:

To pass the symmetric key securely over the network we use the Asymmetric encryption

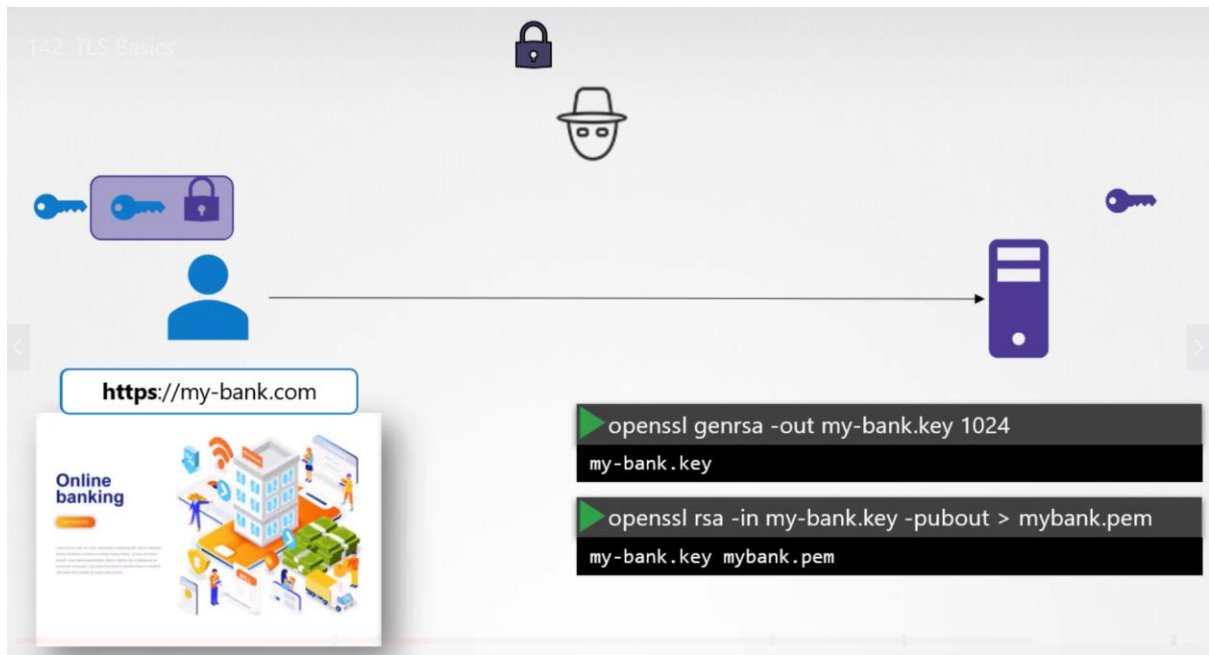
step1: we generate a public and private key on the server, using the openssl command



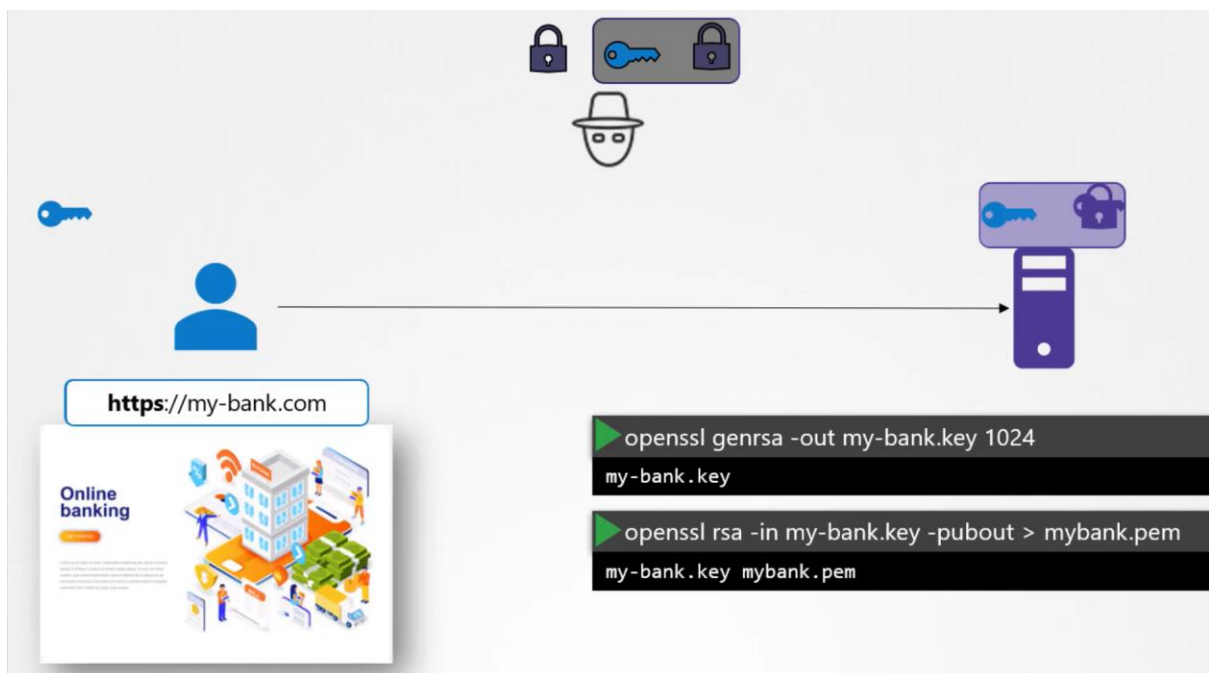
step2: When user first access the server he gets the public key from the server.
The Hacker also get the public key



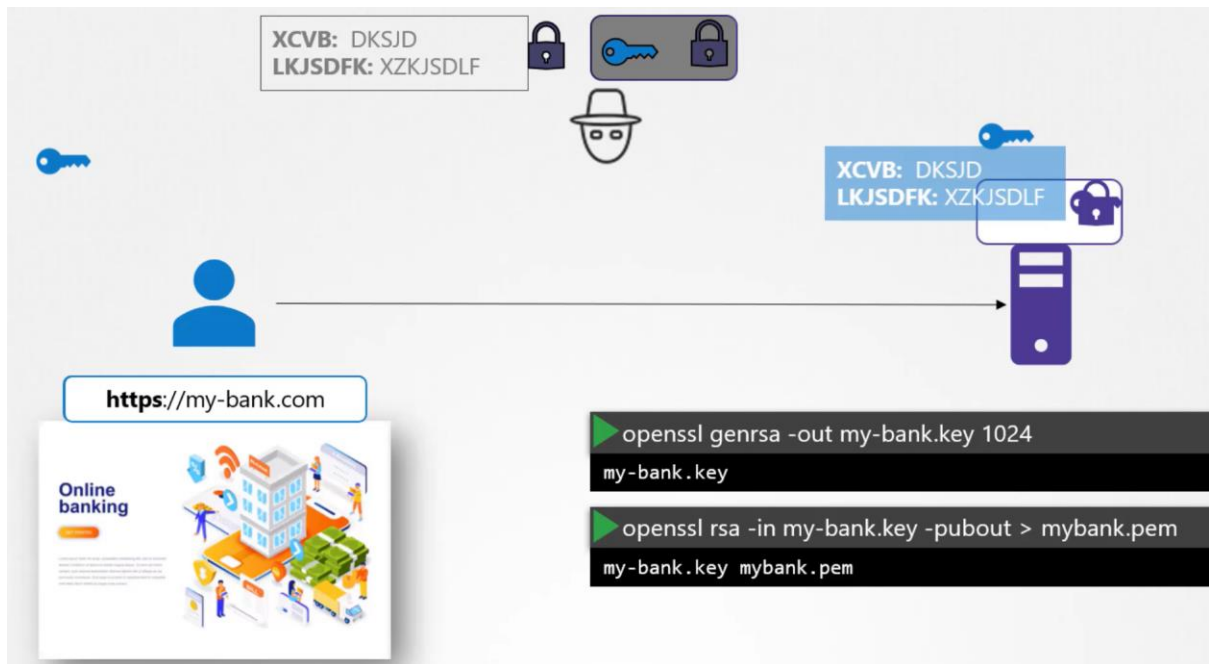
step3: user then encrypt its symmetric key using the public key of the server,
and sends the encrypted key over the network.



step4: Hacker also receives the encrypted message



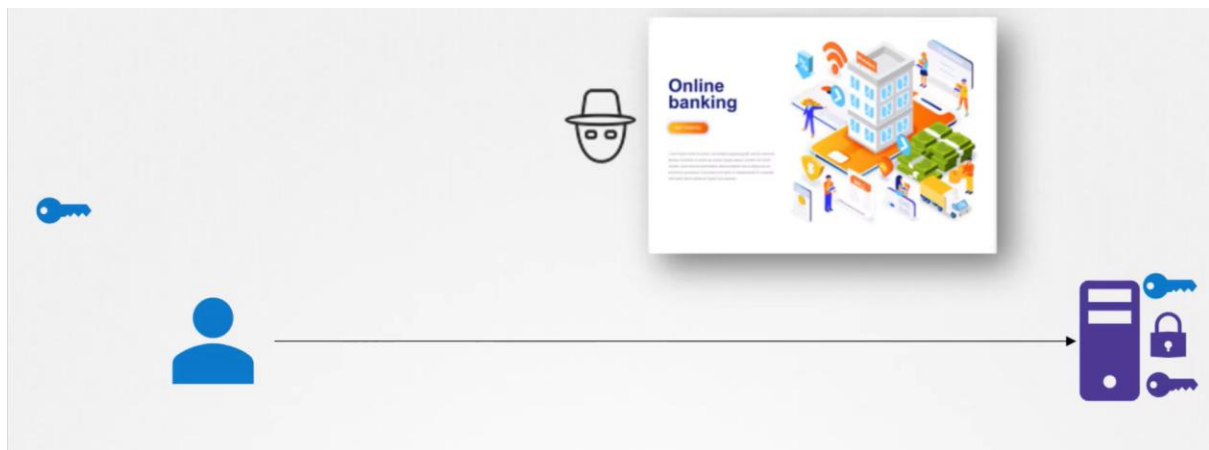
step5: server has a private key can decrypt the message, but hacker don't have private key can't be decrypt the message. Now symmetric key is available to the user and the server, now user can use symmetric key to send the encrypted message to the server and server can use the symmetric key to decrypt the message.



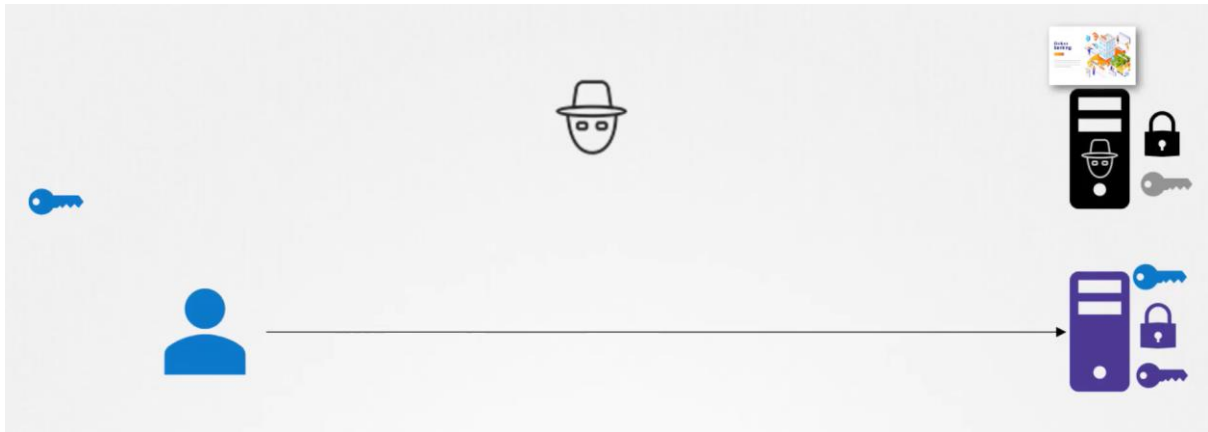
Using the asymmetric encryption, successfully transfer the symmetric key to the server, and using symmetric key we have secure the transaction over the network.

UC: Hacker now looks for new way of hacking

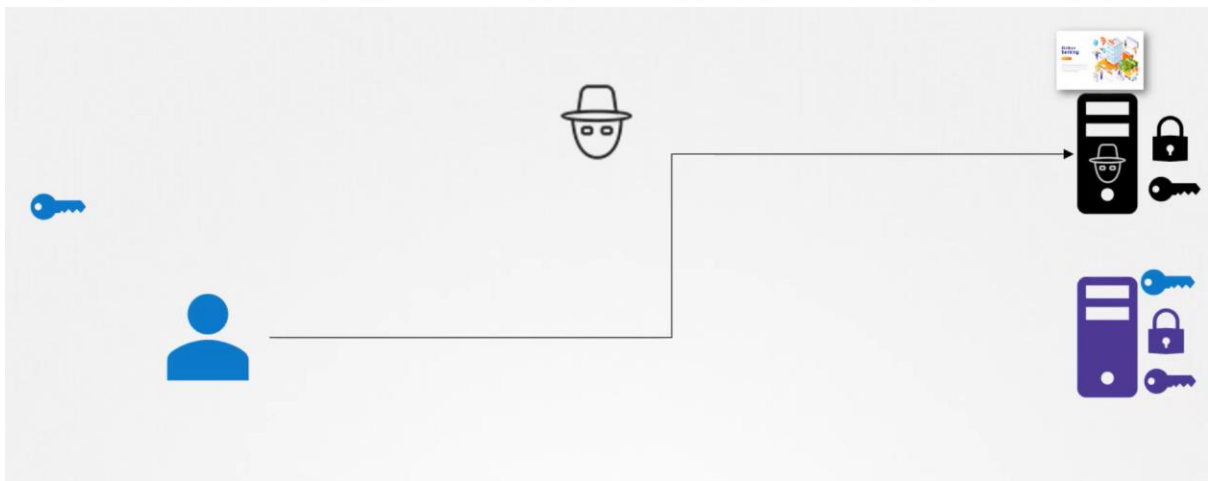
step1: He create a dummy website looks similar to your server.



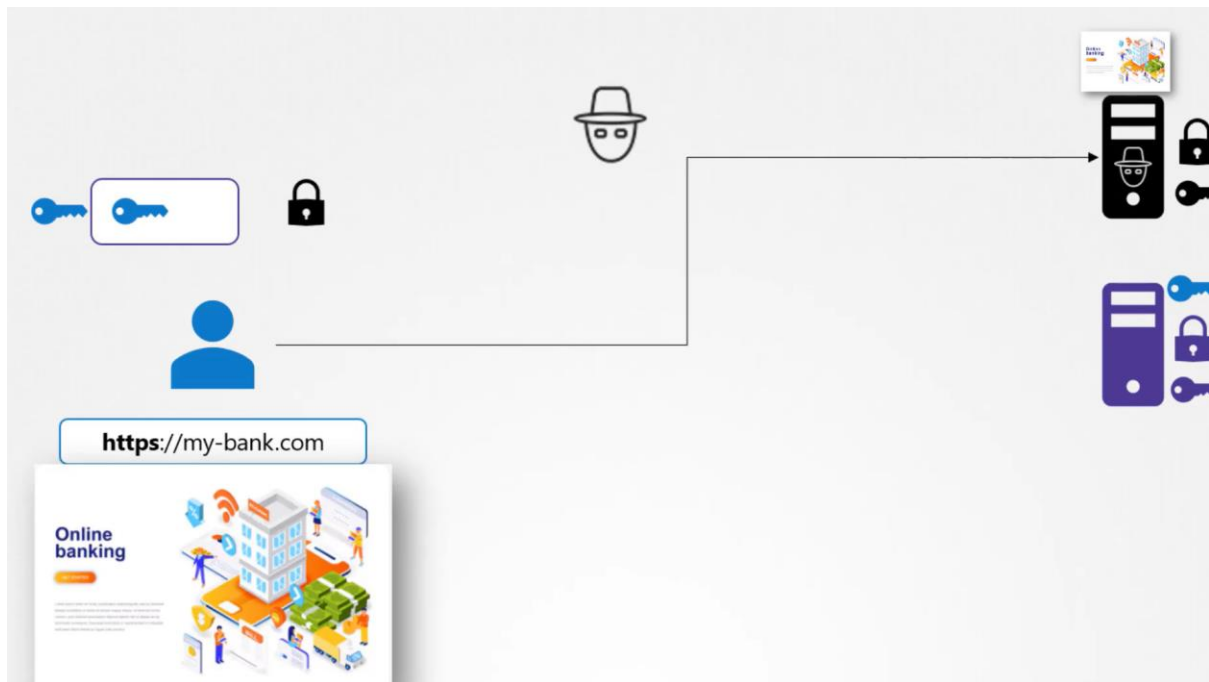
step2: Host the dummy website in his own server, and generate his own private and public key.



step3: Somehow he, tweak that your request forwarded to his server rather than your server.



step4:



How you can confirm that key come from actual server? Server not only send the key also send the certificate that who is it.



UC: Hacker can also generate a certificate?

All the browser have in-build certificate validation mechanism.

Who signed and generate the legitimate certificate?

Certificate Authority, they are well known authorities.

step1: generate a csr (certificate signing request) using the private key

step2: Certificate Authority Validate your Information.

Step3: Sign the certificate and send back to you.

How the browser knows that CA itself is legitimate?

step1: CA itself has a set of public and private key pairs

step2: CA use their private keys to sign the certificate.

Step3: Public key of all legitimate CA is built-in to all the browsers, browser uses the public key to validate the certificate is signed by the legitimate CA.

Step4: These are public CA help us to validate the public websites we visits like bank, email etc. However they don't help on validate the sites that are hosted privately say with in your organization like payroll etc. for that we can host our own private CA, the CA server we can deploy internally within the company, then we can install public key of CA on all employee's browsers, and establish a secure communication within the company.

This whole infrastructure including **CA, servers, people and process of generating and maintain the digital certificate** is known as PKI (public key infrastructure).



Note: If we say we can encrypt data only using public key and decrypt using private key it's not correct, these are two related pair of keys, you can encrypt using any key using any of them and can only decrypt using other. You can't encrypt data using one and decrypt using the same. If you encrypt using private key then anyone having public key can decrypt the message.

Naming conventions

